

Safeguard 3.6: Encrypt Data on End-User Devices

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.

Safeguard 3.7: Establish and Maintain a Data Classification Scheme

Asset Type: Data	Security Function: Identify	IG2	IG3
------------------	-----------------------------	-----	-----

Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as “Sensitive,” “Confidential,” and “Public,” and classify their data according to those labels. Review and update the classification scheme annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.8: Document Data Flows

Asset Type: Data	Security Function: Identify	IG2	IG3
------------------	-----------------------------	-----	-----

Document data flows. Data flow documentation includes service provider data flows and should be based on the enterprise’s data management process. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.9: Encrypt Data on Removable Media

Asset Type: Data	Security Function: Protect	IG2	IG3
------------------	----------------------------	-----	-----

Encrypt data on removable media.

Safeguard 3.10: Encrypt Sensitive Data in Transit

Asset Type: Data	Security Function: Protect	IG2	IG3
------------------	----------------------------	-----	-----

Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).

Safeguard 3.11: Encrypt Sensitive Data at Rest

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Encrypt sensitive data at rest on servers, applications, and databases. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.

Safeguard 3.12: Segment Data Processing and Storage Based on Sensitivity

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Segment data processing and storage based on the sensitivity of the data. Do not process sensitive data on enterprise assets intended for lower sensitivity data.

Safeguard 3.13: Deploy a Data Loss Prevention Solution

Asset Type:	Data	Security Function:	Protect	IG3
-------------	------	--------------------	---------	-----

Implement an automated tool, such as a host-based Data Loss Prevention (DLP) tool to identify all sensitive data stored, processed, or transmitted through enterprise assets, including those located onsite or at a remote service provider, and update the enterprise’s data inventory.

Safeguard 3.14: Log Sensitive Data Access

Asset Type:	Data	Security Function:	Detect	IG3
-------------	------	--------------------	--------	-----

Log sensitive data access, including modification and disposal.

CONTROL 4

Secure Configuration of Enterprise Assets and Software

Safeguards: 12	IG1: 7/12	IG2: 11/12	IG3: 12/12
----------------	-----------	------------	------------

Overview

Establish and maintain the secure configuration of enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/IoT devices; and servers) and software (operating systems and applications).

Why is this Control critical?

As delivered from manufacturers and resellers, the default configurations for enterprise assets and software are normally geared toward ease-of-deployment and ease-of-use rather than security. Basic controls, open services and ports, default accounts or passwords, pre-configured Domain Name System (DNS) settings, older (vulnerable) protocols, and pre-installation of unnecessary software can all be exploitable if left in their default state. Further, these security configuration updates need to be managed and maintained over the life cycle of enterprise assets and software. Configuration updates need to be tracked and approved through configuration management workflow process to maintain a record that can be reviewed for compliance, leveraged for incident response, and to support audits. This CIS Control is important to on-premises devices, as well as remote devices, network devices, and cloud environments.

Service providers play a key role in modern infrastructures, especially for smaller enterprises. They often are not set up by default in the most secure configuration to provide flexibility for their customers to apply their own security policies. Therefore, the presence of default accounts or passwords, excessive access, or unnecessary services are common in default configurations. These could introduce weaknesses that are under the responsibility of the enterprise that is using the software, rather than the service provider. This extends to ongoing management and updates, as some Platform as a Service (PaaS) only extend to the operating system, so patching and updating hosted applications are under the responsibility of the enterprise.

Even after a strong initial configuration is developed and applied, it must be continually managed to avoid degrading security as software is updated or patched, new security vulnerabilities are reported, and configurations are “tweaked,” to allow the installation of new software or to support new operational requirements.

Procedures and tools

There are many available security baselines for each system. Enterprises should start with these publicly developed, vetted, and supported security benchmarks, security guides, or checklists. Some resources include:

The CIS Benchmarks® Program: <http://www.cisecurity.org/cis-benchmarks/>

The National Institute of Standards and Technology (NIST®) National Checklist Program Repository: <https://nvd.nist.gov/ncp/repository>

Enterprises should augment or adjust these baselines to satisfy enterprise security policies, and industry and government regulatory requirements. Deviations of standard configurations and rationale should be documented to facilitate future reviews or audits.

For a larger or more complex enterprise, there will be multiple security baseline configurations based on security requirements or classification of the data on the enterprise asset. Here is an example of the steps to build a secure baseline image:

- 1 Determine the risk classification of the data handled/stored on the enterprise asset (e.g., high, moderate, low risk).
- 2 Create a security configuration script that sets system security settings to meet the requirements to protect the data used on the enterprise asset. Use benchmarks, such as the ones described earlier in this section.
- 3 Install the base operating system software.
- 4 Apply appropriate operating system and security patches.
- 5 Install appropriate application software packages, tool, and utilities.
- 6 Apply appropriate updates to software installed in Step 4.
- 7 Install local customization scripts to this image.
- 8 Run the security script created in Step 2 to set the appropriate security level.
- 9 Run a tool to record/score the system setting of the baseline image.
- 10 Perform a security quality assurance test.
- 11 Save this base image in a secure location.

Commercial and/or free configuration management tools, such as the CIS Configuration Assessment Tool (CIS-CAT®) <https://learn.cisecurity.org/cis-cat-lite>, can be deployed to measure the settings of operating systems and applications of managed machines to look for deviations from the standard image configurations. Commercial configuration management tools use some combination of an agent installed on each managed system, or agentless inspection of systems through remotely logging into each enterprise asset using administrator credentials. Additionally, a hybrid approach is sometimes used whereby a remote session is initiated, a temporary or dynamic agent is deployed on the target system for the scan, and then the agent is removed.

Safeguards

Safeguard 4.1: Establish and Maintain a Secure Configuration Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented secure configuration process for enterprise assets (end-user devices, including portable and mobile, non-computing/IoT devices, and servers) and software (operating systems and applications). Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.

Safeguard 4.4: Implement and Manage a Firewall on Servers

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.

Safeguard 4.5: Implement and Manage a Firewall on End-User Devices

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.

Safeguard 4.6: Securely Manage Enterprise Assets and Software

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Securely manage enterprise assets and software. Example implementations include managing configuration through version-controlled Infrastructure-as-Code (IaC) and accessing administrative interfaces over secure network protocols, such as Secure Shell (SSH) and Hypertext Transfer Protocol Secure (HTTPS). Do not use insecure management protocols, such as Telnet (Teletype Network) and HTTP, unless operationally essential.

Safeguard 4.7: Manage Default Accounts on Enterprise Assets and Software

Asset Type:	Users	Security Function:	Protect	IG1	IG2	IG3
-------------	-------	--------------------	---------	-----	-----	-----

Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.

Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.

Safeguard 4.9: Configure Trusted DNS Servers on Enterprise Assets

Asset Type: Devices	Security Function: Protect	IG2 IG3
----------------------------	-----------------------------------	-----------------------

Configure trusted DNS servers on network infrastructure. Example implementations include configuring network devices to use enterprise-controlled DNS servers and/or reputable externally accessible DNS servers.

Safeguard 4.10: Enforce Automatic Device Lockout on Portable End-User Devices

Asset Type: Devices	Security Function: Protect	IG2 IG3
----------------------------	-----------------------------------	-----------------------

Enforce automatic device lockout following a predetermined threshold of local failed authentication attempts on portable end-user devices, where supported. For laptops, do not allow more than 20 failed authentication attempts; for tablets and smartphones, no more than 10 failed authentication attempts. Example implementations include Microsoft® InTune Device Lock and Apple® Configuration Profile maxFailedAttempts.

Safeguard 4.11: Enforce Remote Wipe Capability on Portable End-User Devices

Asset Type: Data	Security Function: Protect	IG2 IG3
-------------------------	-----------------------------------	-----------------------

Remotely wipe enterprise data from enterprise-owned portable end-user devices when deemed appropriate such as lost or stolen devices, or when an individual no longer supports the enterprise.

Safeguard 4.12: Separate Enterprise Workspaces on Mobile End-User Devices

Asset Type: Data	Security Function: Protect	IG3
-------------------------	-----------------------------------	------------

Ensure separate enterprise workspaces are used on mobile end-user devices, where supported. Example implementations include using an Apple® Configuration Profile or Android™ Work Profile to separate enterprise applications and data from personal applications and data.

CONTROL 5

Account Management

Safeguards: 6	IG1: 4/6	IG2: 6/6	IG3: 6/6
---------------	----------	----------	----------

Overview

Use processes and tools to assign and manage authorization to credentials for user accounts, including administrator accounts, as well as service accounts, to enterprise assets and software.

Why is this Control critical?

It is easier for an external or internal threat actor to gain unauthorized access to enterprise assets or data through using valid user credentials than through “hacking” the environment. There are many ways to covertly obtain access to user accounts, including: weak passwords, accounts still valid after a user leaves the enterprise, dormant or lingering test accounts, shared accounts that have not been changed in months or years, service accounts embedded in applications for scripts, a user having the same password as one they use for an online account that has been compromised (in a public password dump), social engineering a user to give their password, or using malware to capture passwords or tokens in memory or over the network.

Administrative, or highly privileged, accounts are a particular target, because they allow attackers to add other accounts, or make changes to assets that could make them more vulnerable to other attacks. Service accounts are also sensitive, as they are often shared among teams, internal and external to the enterprise, and sometimes not known about, only to be revealed in standard account management audits.

Finally, account logging and monitoring is a critical component of security operations. While account logging and monitoring are covered in CIS Control 8 (Audit Log Management), it is important in the development of a comprehensive Identity and Access Management (IAM) program.

Procedures and tools

Accounts must be tracked; any account that is dormant must be disabled and eventually removed from the system. There should be periodic audits to ensure all active accounts are traced back to authorized users of the enterprise asset. Look for new accounts added since previous review, especially administrator and service accounts. Close attention should be made to identify and track administrative, or high-privileged accounts and service accounts.

Users with administrator or other privileged access should have separate accounts for those higher authority tasks. These accounts would only be used when performing those tasks or accessing especially sensitive data, to reduce risk in case their normal user account is compromised. For users with multiple accounts, their base user account, used day-to-day for non-administrative tasks, should not have any elevated privileges.

Single Sign-On (SSO) is convenient and secure when an enterprise has many applications, including cloud applications, which helps reduce the number of passwords a user must manage. Users are recommended to use password manager applications to securely store their passwords, and should be instructed not to keep them in spreadsheets or text files on their computers. MFA is recommended for remote access.

Users must also be automatically logged out of the system after a period of inactivity, and be trained to lock their screen when they leave their device to minimize the possibility of someone else in physical proximity around the user accessing their system, applications, or data.

An excellent resource is the NIST® Digital Identity Guidelines: <https://pages.nist.gov/800-63-3/>

For guidance on the creation and use of passwords, reference the CIS Password Policy Guide: <https://www.cisecurity.org/white-papers/cis-password-policy-guide>

Safeguards

Safeguard 5.1: Establish and Maintain an Inventory of Accounts

Asset Type: Users	Security Function: Identify	IG1	IG2	IG3
-------------------	-----------------------------	-----	-----	-----

Establish and maintain an inventory of all accounts managed in the enterprise. The inventory must at a minimum include user, administrator, and service accounts. The inventory, at a minimum, should contain the person’s name, username, start/stop dates, and department. Validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.

Safeguard 5.2: Use Unique Passwords

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using Multi-Factor Authentication (MFA) and a 14-character password for accounts not using MFA.

Safeguard 5.3: Disable Dormant Accounts

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.

Safeguard 5.4: Restrict Administrator Privileges to Dedicated Administrator Accounts

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user’s primary, non-privileged account.

Safeguard 5.5: Establish and Maintain an Inventory of Service Accounts

Asset Type: Users	Security Function: Identify	IG2	IG3
-------------------	-----------------------------	-----	-----

Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.

Safeguard 5.6: Centralize Account Management

Asset Type: Users	Security Function: Govern	IG2	IG3
-------------------	---------------------------	-----	-----

Centralize account management through a directory or identity service.